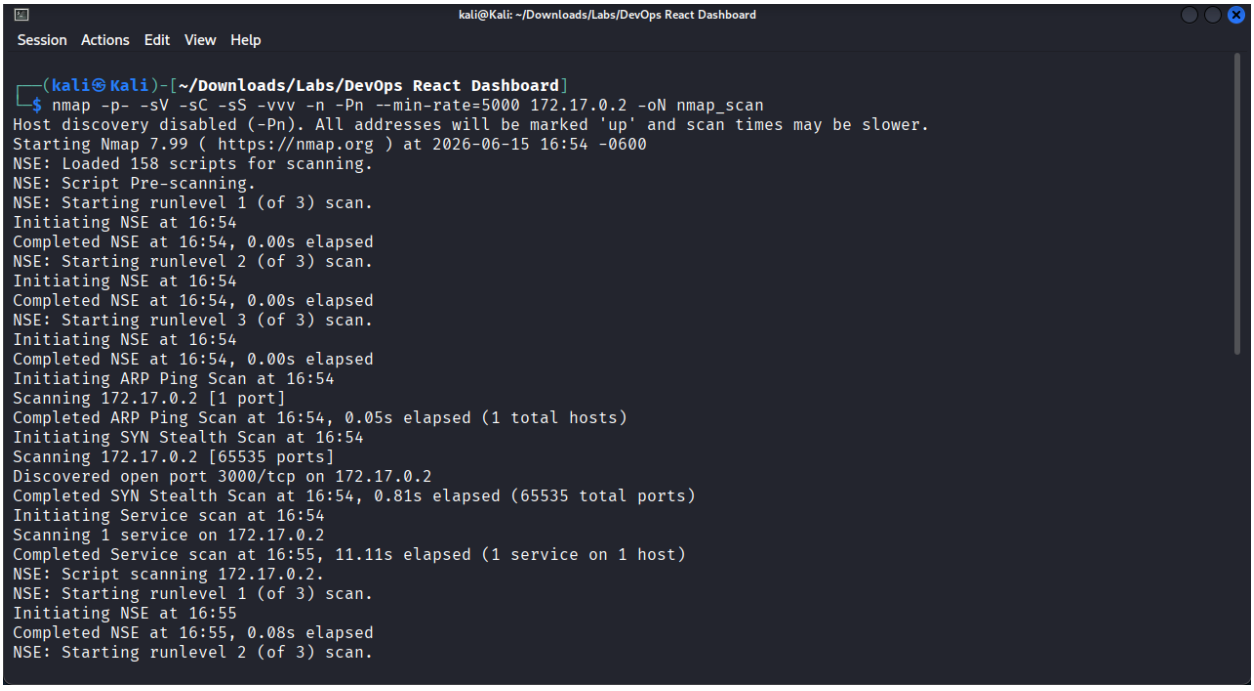
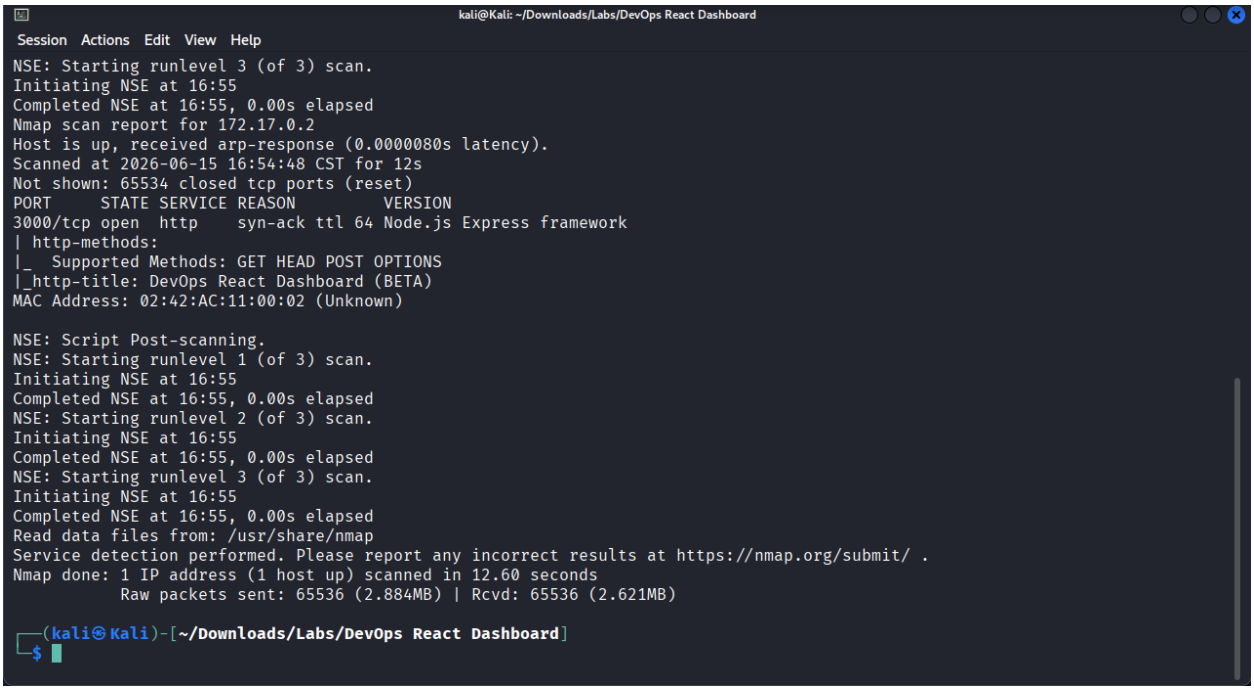
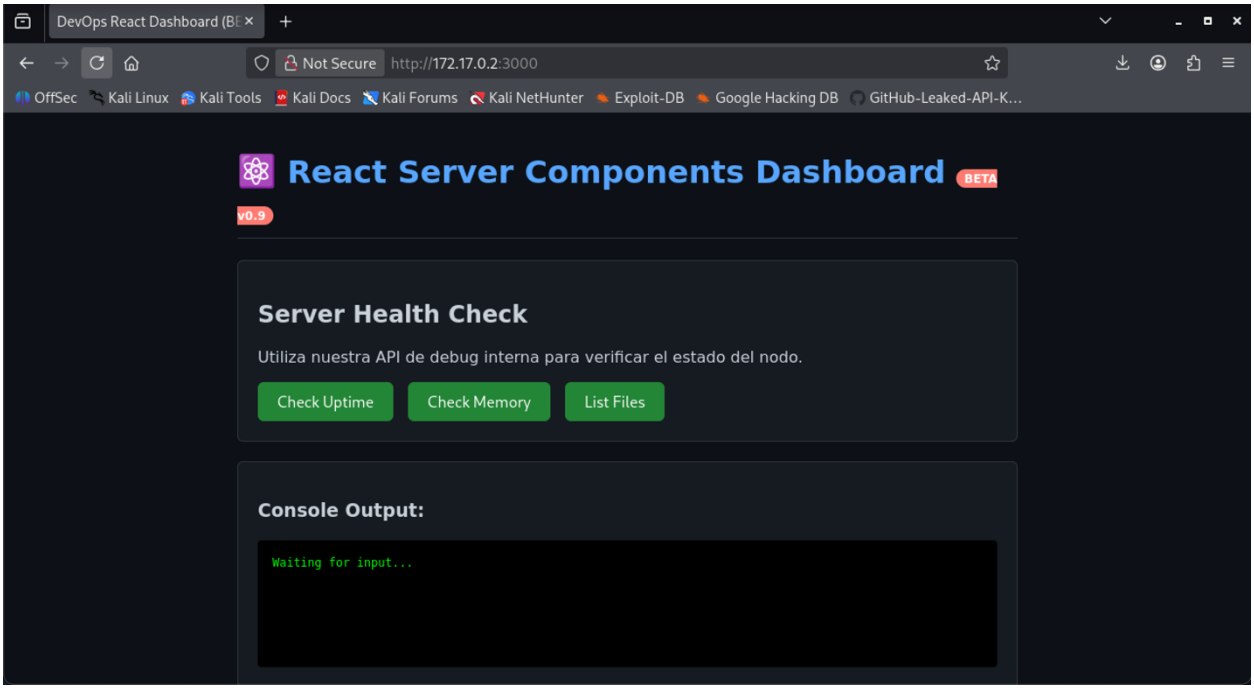
Iniciamos el lab DevOps React Dashboard

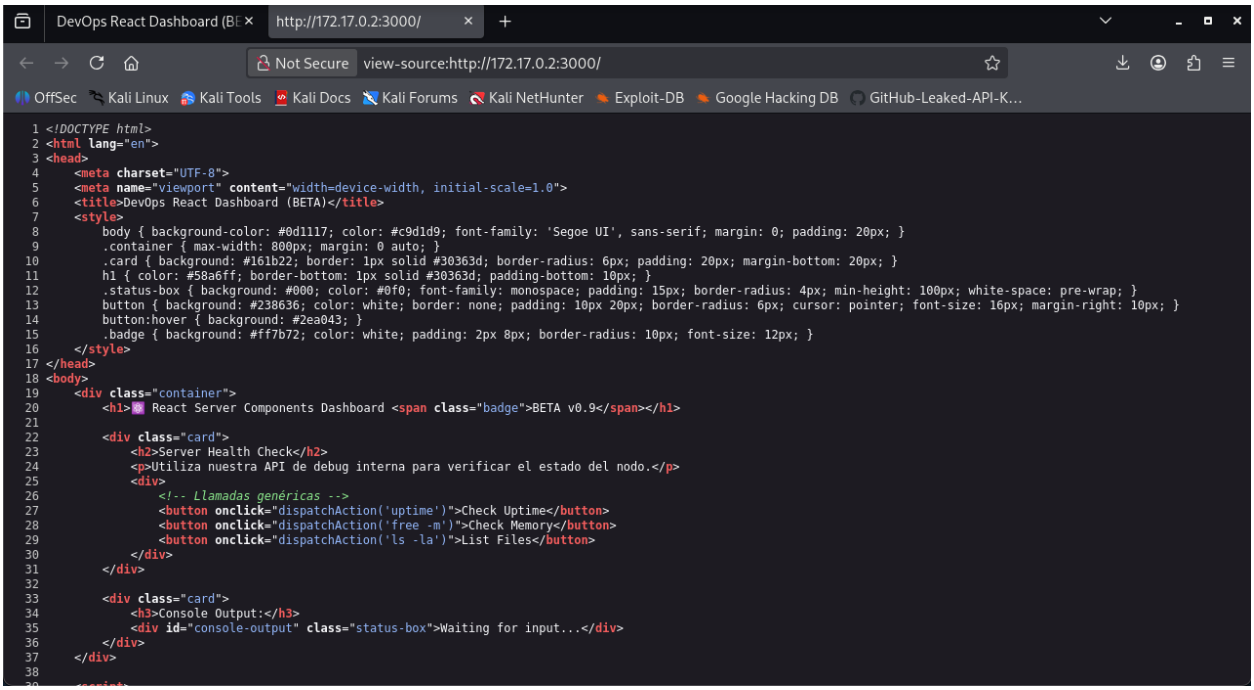
Una vez cargado el lab obtenemos el IP de la máquina a vulnerar, comenzaremos realizando un escaneo de puertos con nmap -p- -sV -sC -sS -vvv -n -Pn --min-rate=5000 172.17.0.2 -oN nmap_scan



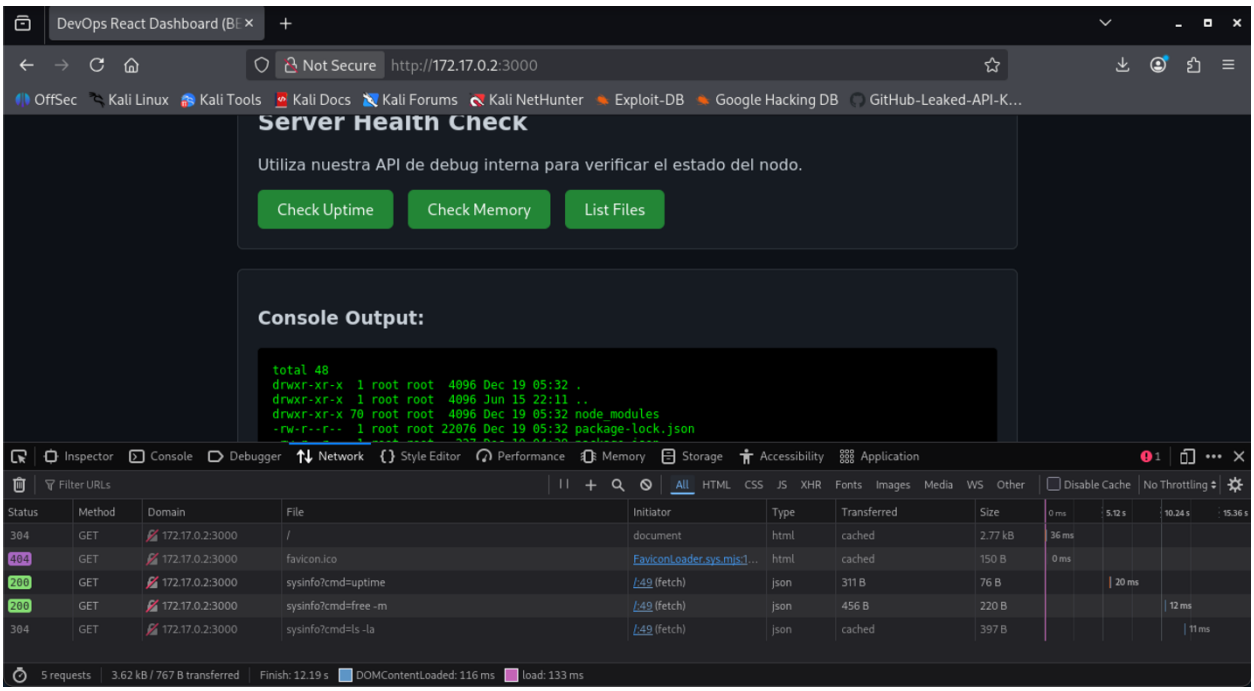


Hemos obtenido que tiene el puerto 3000 abierto para http, verifiquemos la página web y su código fuente para ver si podemos obtener alguna información que nos sea de utilidad.

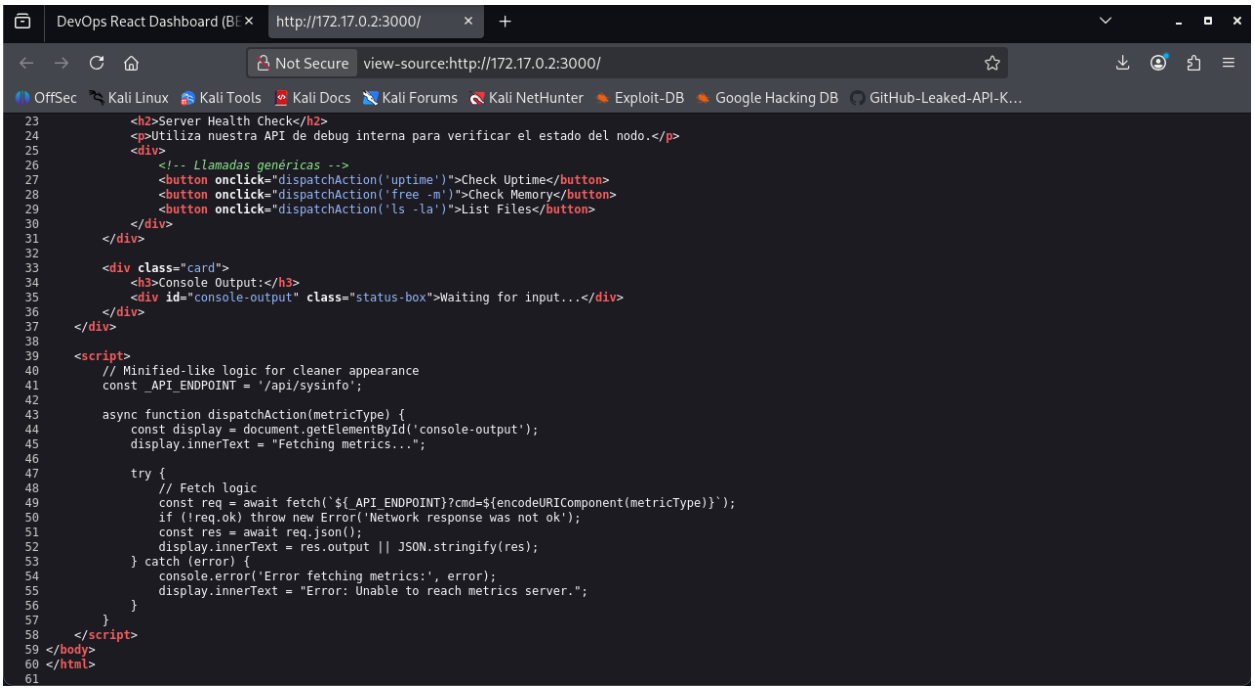




Ahora usaremos las herramientas de desarrollo en la parte de red para ver archivos JS/CSS cargados.

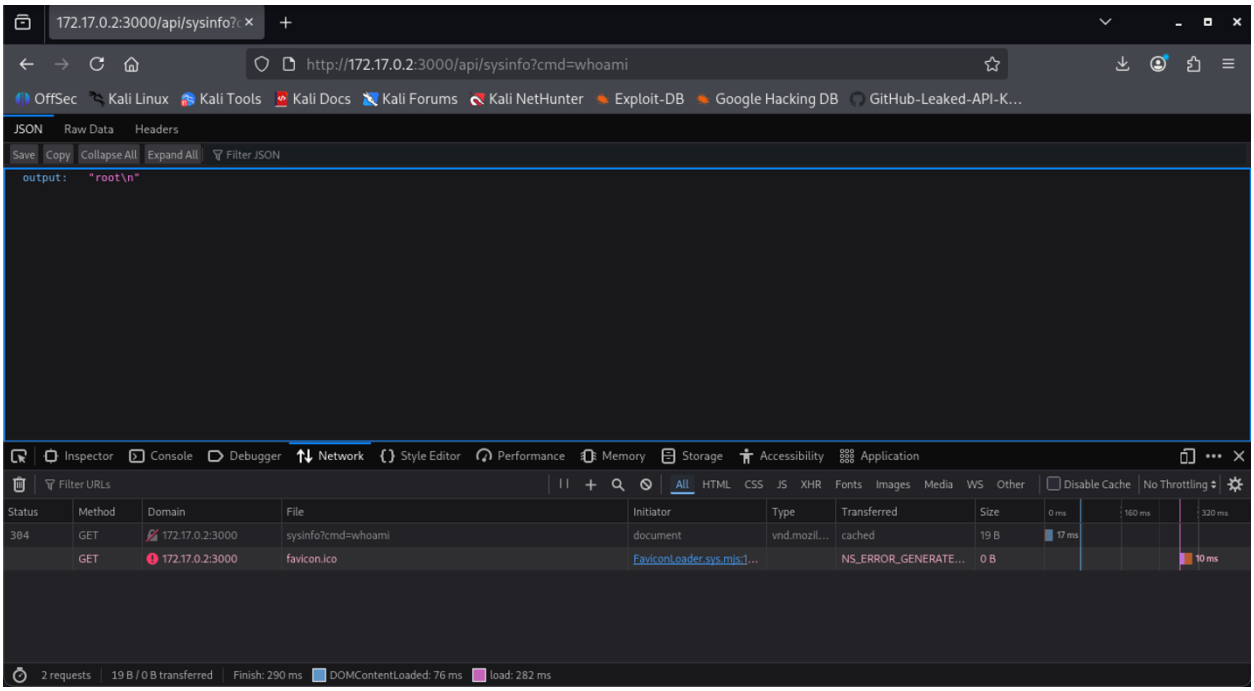


SI observamos bien cada vez que presionamos uno de los botones manda a ejecutar un comando siguiendo la misma lógica que un web shell.

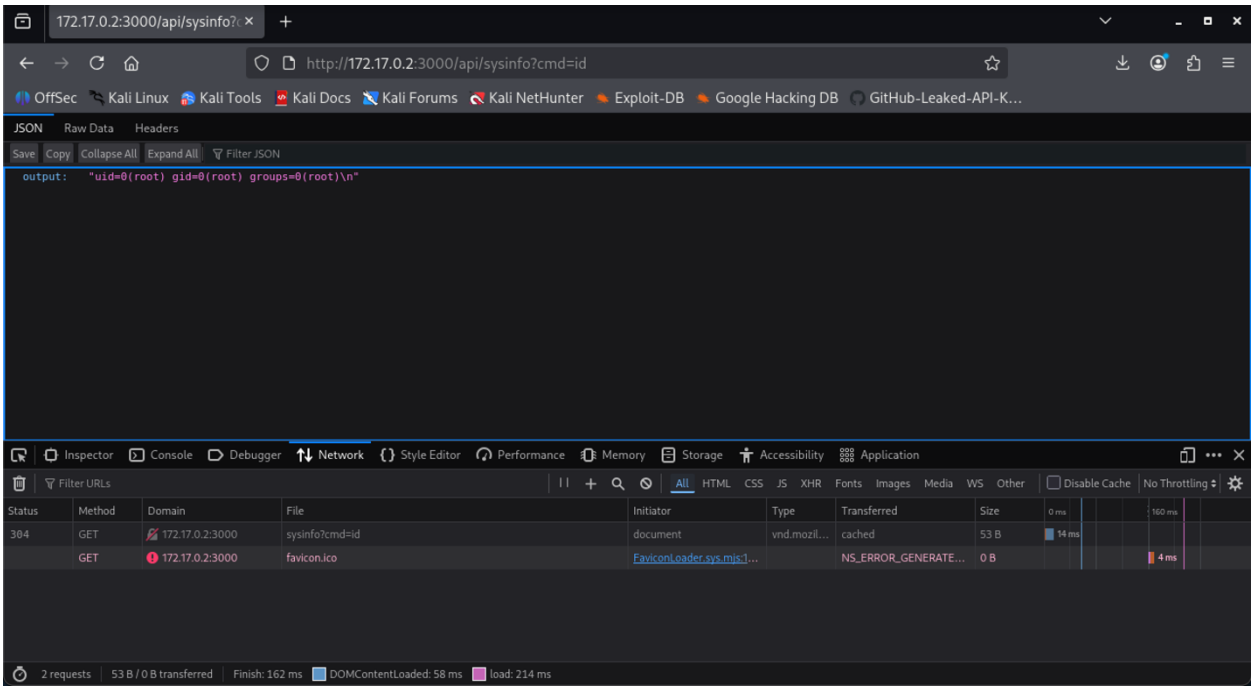


También al revisar el código de la página vemos que hay una sección de un script donde hacen referencia a la ruta /api/sysinfo.

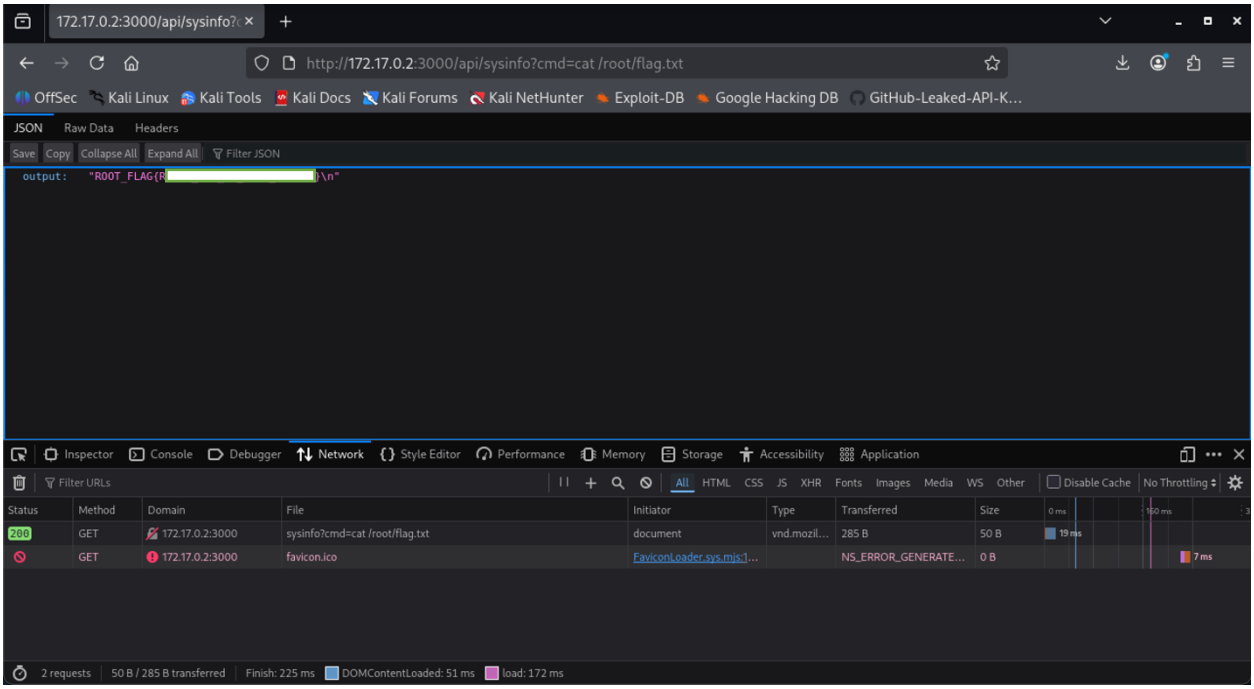
Probemos si esta página está expuesta como una web shell, mandaremos a ejecutar el comando whoami



Obtenemos como salida root, ahora verifiquemos con el comando id



Esto nos confirma que todos los comandos los está ejecutando como root por lo que solo nos queda ir a leer el contenido de la bandera



Una vez obtenida la bandera la verificamos introduciéndola en la terminal donde levantamos el lab


kali@Kali: ~/Downloads/Labs/DevOps React Dashboard
Session Actions Edit View Help
Bienvenido a WHOAMI-LABS.COM.
Aprende, simula, escala. Sin burocracia.
[√] Imagen cargada correctamente.
[*] Iniciando laboratorio ...
[√] Laboratorio iniciado correctamente.
[√] Laboratorio desplegado correctamente.
LAB: DEVOPS REACT DASHBOARD
DIFICULTAD: ★ Fácil (1 punto)
IP del laboratorio (Interna): 172.17.0.2
Ingresa la ROOT flag: ROOT_FLAG{R
¡Felicitaciones hacker! Has conseguido la flag.
¿Quieres eliminar la máquina? (s/n):